



O-AA™ Security Playbook

The Open Group Guide

Table of Contents

- O-AA Security Playbook 1
 - Preface 3
 - The Open Group 3
 - This Document 3
 - About the O-AA Playbooks 4
 - About the Authors 5
 - Trademarks 6
 - Acknowledgments 7
 - Referenced Documents 8
 - 1. Introduction 10
 - 1.1. Security in a Digital and Agile World 10
 - 2. The Role of an Agile Security Architect 12
 - 2.1. What Does an Agile Security Architect Do? 12
 - 3. Governance of an Agile Security Architecture 14
 - 4. Desired Characteristics of Architecting Security 16
 - 4.1. Rely on Layers of Controls 16
 - 4.2. Employ Application Security Development Practices 16
 - 5. Agile Security Architecture as an Artifact 18
 - 6. Future Directions 20
 - Appendix A: Acronyms 21
- Index 22

O-AA Security Playbook

The Open Group Guide

Copyright © 2021, The Open Group
All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by any means, electronic, mechanical, photocopying, recording, or otherwise, without the prior permission of the copyright owners.

Any use of this publication for commercial purposes is subject to the terms of the Annual Commercial License relating to it. For further information, see www.opengroup.org/legal/licensing.

The Open Group Guide
O-AA™ Security Playbook
Document Number: G216
ISBN: 1-947754-75-1

Published by The Open Group, March 2021.

Comments relating to the material contained in this document may be submitted to:

The Open Group, Apex Plaza, Forbury Road, Reading, Berkshire, RG1 1AX, United Kingdom
or by electronic mail to:
ogspecs@opengroup.org

Built with [asciidocctor](#), version 2.0.10. Backend: pdf Build date: 2021-03-12 06:27:23 UTC

Preface

The Open Group

The Open Group is a global consortium that enables the achievement of business objectives through technology standards. Our diverse membership of more than 800 organizations includes customers, systems and solutions suppliers, tools vendors, integrators, academics, and consultants across multiple industries.

The mission of The Open Group is to drive the creation of Boundaryless Information Flow™ achieved by:

- Working with customers to capture, understand, and address current and emerging requirements, establish policies, and share best practices
- Working with suppliers, consortia, and standards bodies to develop consensus and facilitate interoperability, to evolve and integrate specifications and open source technologies
- Offering a comprehensive set of services to enhance the operational efficiency of consortia
- Developing and operating the industry's premier certification service and encouraging procurement of certified products

Further information on The Open Group is available at www.opengroup.org.

The Open Group publishes a wide range of technical documentation, most of which is focused on development of Standards and Guides, but which also includes white papers, technical studies, certification and testing documentation, and business titles. Full details and a catalog are available at www.opengroup.org/library.

This Document

This document is the O-AA™ Security Playbook. It has been developed and approved by The Open Group.

The high-level structure of this document is summarized as follows:

- [Chapter 1](#) provides an overview of this document
- [Chapter 2](#) describes the role of an Agile security architect
- [Chapter 3](#) describes governance of an Agile security architecture
- [Chapter 4](#) describes desired characteristics of architecting security
- [Chapter 5](#) describes Agile security architecture as an artifact
- [Chapter 6](#) describes future directions for this document and additional publications

The target audience for this document includes:

- Product owners and project managers seeking to understand and support the role of security architecture in Agile development
- Those accountable for overall systems security architecture by continually balancing business enablement through speed and risk management through security
- Agilists who need to understand the importance of architecture when shifting toward an Agile at scale model
- Enterprise Architects who want to stay relevant in an Agile at scale and digital world

About the O-AA Playbooks

The O-AA playbooks support the O-AA Standard, and form part of the O-AA Body of Knowledge. Each O-AA playbook provides guidelines to solve a particular Agile Architecture problem; for example, how to address cross-cutting concerns such as security or to cover a specific problem such as how to handle legacy systems when developing a digital platform.

Playbooks help modularize the O-AA approach, and are expected to be added on a continuous basis to the O-AA Body of Knowledge. Before an O-AA playbook is added or is updated, it goes through a formal review and approval process within The Open Group.

About the Authors

Christopher Carlson

Christopher Carlson is a Certified Information System Security Professional and is Open FAIR™ Certified. He finished his 39-year career at the Boeing Company as an Associate Technical Fellow before establishing C.T. Carlson LLC to provide information security writings and advisory services. Management highlights at Boeing include leading the company-wide classified computing security program; 777 Program Security Manager; and Chief Security Officer for the sonic cruiser program, forerunner of the 787. Selected technical responsibilities at Boeing included defining requirements and leading implementation of a role-based access management system; introducing secure application development methods; system management of a governance, risk, and compliance system; and leading selection and implementation of a data security and insider threat detection system.

Anthony Carrato

Anthony Carrato is a long-time participant in The Open Group, dating back to the Open Software Foundation in the early 1990s. He was active in the early days of the Architecture Forum; a long-time co-chair of the Service-Oriented Architecture (SOA) Work Group and currently a member of the Steering Committee of the Security Forum. Tony, who retired from IBM in late 2019, is certified as a Distinguished IT Architect in The Open Group Professions program, and has 42 Acclaim badges overall. Tony is currently an Invited Expert of The Open Group Security Forum.

Altaz Valani

Altaz Valani, Director of Research at Security Compass, manages the overall research vision and team. He is a regular conference speaker who conducts ongoing research in the Software Security domain. Prior to joining Security Compass, he was a Senior Research Director and Executive Advisor at Info-Tech Research Group, Senior Manager at KPMG, as well as various positions working alongside senior stakeholders to drive business value through software development. He is a frequent collaborator within industry and academic circles on a wide range of topics related to governance, risk, cybersecurity, and software development. Altaz is currently serving as the Security Forum Vice-Chair.

Trademarks

ArchiMate, DirecNet, Making Standards Work, Open O logo, Open O and Check Certification logo, Platform 3.0, The Open Group, TOGAF, UNIX, UNIXWARE, and the Open Brand X logo are registered trademarks and Boundaryless Information Flow, Build with Integrity Buy with Confidence, Commercial Aviation Reference Architecture, Dependability Through Assuredness, Digital Practitioner Body of Knowledge, DPBoK, EMMM, FACE, the FACE logo, FHIM Profile Builder, the FHIM logo, FPB, Future Airborne Capability Environment, IT4IT, the IT4IT logo, O-AA, O-DEF, O-HERA, O-PAS, Open Agile Architecture, Open FAIR, Open Footprint, Open Process Automation, Open Subsurface Data Universe, Open Trusted Technology Provider, OSDU, Sensor Integration Simplified, SOSA, and the SOSA logo are trademarks of The Open Group.

All other brands, company, and product names are used for identification purposes only and may be trademarks that are the sole property of their respective owners.

Acknowledgments

The Open Group gratefully acknowledges the contribution of the following people in the development of this document:

- Christopher Carlson, C.T. Carlson LLC
- Anthony Carrato, Invited Expert
- Frederic Le, DXC Technology
- John Linford, Forum Director, Security Forum & Open Trusted Technology Forum (OTTF), The Open Group
- Altaz Valani, Security Compass

The Open Group gratefully acknowledges the following reviewers who participated in the Company Review of this document:

- Christopher Frost, Fujitsu
- Sriram Sabesan, Accenture

Referenced Documents

The following documents are referenced in this Guide.

(Please note that the links below are good at the time of writing but cannot be guaranteed for the future.)

- [1] *Open Agile Architecture™ Standard, also known as the O-AA™ Standard*, a standard of The Open Group (C208), September 2020, published by The Open Group; refer to: www.opengroup.org/library/c208
- [2] *The Open Group Standard for Risk Taxonomy (O-RT), Version 2.0*, a standard of The Open Group (C13K), October 2013, published by The Open Group; refer to: www.opengroup.org/library/c13k
- [3] *Design Defense in Depth*, by Christopher T. Carlson, May 2020; refer to: ctcarlsoncom.wordpress.com/2020/05/28/design-defense-in-depth/
- [4] *DevOps: A Software Architect's Perspective*, by Len Bass, Ingo Weber, and Liming Zhu, May 2015, published by Addison-Wesley
- [5] *Cybersecurity Maturity Model Certification (CMMC), Volume 1.02*, March 2020, published by Carnegie Mellon University and The John Hopkins University Applied Physics Laboratory, LLC; refer to www.acq.osd.mil/cmmc/docs/CMMC_ModelMain_V1.02_20200318.pdf

The following documents supplement the contents in this Guide.

- *Agile Architecture in the Digital Era: Trends and Practices*, by Zoran Dragičević and Saša Bošnjak, January 2019, published in Strategic Management, Volume 24(2) by the Centre for Evaluation in Education and Science
- *Agile System Architecture in Large Organizations: An Experience Report from Volvo Cars*, by Darko Durisic & Attila Berényi, March 2019, published by IEEE; refer to: <https://ieeexplore.ieee.org/document/8712378>
- *Agility, Risk, and Uncertainty, Part 1: Designing an Agile Architecture*, by Michael Waterman, March 2018, published by IEEE; refer to: <https://ieeexplore.ieee.org/document/8314169>
- *Architects Working Agile: Methods and Challenges*, by Martin Wellme. 2019, published by the KTH Royal Institute of Technology, School of Electrical Engineering and Computer Science
- *Continuous Architecture: Towards the Goldilocks Zone and Away from Vicious Circles*, by Torvaid Mårtensson et al., March 2019, published by IEEE
- *Designing Software Architecture to Support Continuous Delivery and DevOps: A Systematic Literature Review*, by Robin Bolscher and Maya Daneva, 2019, Conference Paper: 14th International Conference on Software Technologies (ICSOF 2019)
- *DevSecOps: A Comprehensive Approach to Secure Applications*, by DXC Technology; refer to: www.dxc.technology/security/insights/146543-devsecops_a_comprehensive_approach_to_secure_applications

- *Extracting Quality Attributes from User Stories for Early Architecture Decision Making*, by Fabian Gilson, Matthias Galster, and Francois Georis, March 2019, published by IEEE
- *High-Level Design Stories in Architecture-Centric Agile Development*, by Jorge Andrés Díaz Pace and Alejandro J. Bianchi, March 2019, published by IEEE; refer to: is.ieis.tue.nl/research/bpm/MARCH/wp-content/uploads/2019/02/MARCH_2019_paper_5-1.pdf
- *Improving the Consistency and Usefulness of Architecture Descriptions: Guidelines for Architects*, by Rebekka Wohlrab et al., August 2019, published by IEEE
- *Security Architecture for Cloud Applications – Five Facets of Secure DevOps*, by IBM; refer to: www.ibm.com/cloud/architecture/architectures/securityArchitecture/implement-secure-devops/
- *Using Social Network Analysis to Investigate the Collaboration Between Architects and Agile Teams: A Case Study of a Large-Scale Agile Development Program in a German Consumer Electronics Company*, by Ömer Uludağ et al., April 2019, published by XP in Agile Processes in Software Engineering and Extreme Programming
- *What are the Microsoft SDL Practices?*, by Microsoft; refer to: www.microsoft.com/en-us/securityengineering/sdl/practices
- *What is DevSecOps?*, by Palo Alto Networks; refer to: www.paloaltonetworks.com/cyberpedia/what-is-devsecops
- *What is DevSecOps?*, by Red Hat; refer to: www.redhat.com/en/topics/devops/what-is-devsecops

Chapter 1. Introduction

This document is the O-AA Security Playbook. It provides guidelines for addressing security in an Agile Architecture – to enable the business to move rapidly in a world of defined and managed risk. Security is a vast topic, and this document does not intend to fully address all IT security considerations for Agile Architectures, but instead offers an overview of the topic with links to additional information as needed. As such, the beginning of this document contains links to supplementary materials to provide detail about topics intentionally left brief. This document is intended to align with the Open Agile Architecture™ Standard [1] and to provide directions for further learning.

1.1. Security in a Digital and Agile World

Security is a crucial element in any Agile Architecture, and we must get it right. Businesses are in a world of digital enablement and iterative development with the Minimum Security Architecture (MSA) as a crucial element of Agile development. The MSA is a continually evolving security architecture that fits into the cadence of a DevOps cycle and is sufficient to guide developers toward the Minimum Viable Product (MVP) and to set architectural direction for future releases.

However, with this comes a danger: if an MVP is released with a security gap it is difficult to apply a solution once it has gained a user community. This means that products must correctly integrate security into the architecture from the beginning or risk the difficult – if not impossible – task of trying to remediate security gaps later on.

DevOps includes security as a fundamental aspect; it is not an add-on to the process. This prevents the silo thinking prevalent in literature, which attempts to add additional teams to DevOps leading to infinite variations of DevSecOps, ArchDevOps, etc. The DevOps process (while technical in execution) is owned by the business. As such, the goal of DevOps is to help balance both business enablement and risk management (in the context of security). This can take the form of compliance and resiliency metrics that provide much needed assurance to the business in relation to system-related cybersecurity.

In addition to building security into the architecture from the beginning, security in an Agile Architecture must respond quickly through regular feedback loops that do not require extensive upfront planning. Because of these rapid feedback loops, there is a need for extra attention in order to balance security with other aspects of the architecture. The security team must consider the future state well beyond the current architecture to ensure that downstream teams also remain Agile. This underscores the purpose of security in an Agile Architecture – to enable the business to move rapidly in a world of defined and managed risk.

To this end, this document follows three core philosophies:

1. An Agile security architecture must be built in short, rapid cycles.
2. Any changes to the security architecture must apply to the environment of each team.
3. Security architects and champions will ensure any architecture complies with the organization's

predefined risk appetite.

These philosophies are the result of over 15 years' combined industry experience in handling security for Agile projects.

Chapter 2. The Role of an Agile Security Architect

An **architect** designs architectures that manage business risk while enabling the business. They are responsible for the balanced and informed implementation of architectural controls that match the risk threshold set by business stakeholders.

A **solution architect** works to understand the business problem; design the overall solution; guide the development team(s) as they implement the solution; and, along with the business owner of the solution, provide overall governance for the solution development program. In an Agile program, architecture designs are delivered in chunks, which are often referred to as “sprints”. The solution architect provides overall technical guidance across the sprints.

A **security architect** supports product and solution architects by emphasizing security in the design.

An **Agile security architect** reframes the traditional security architect role in several ways:

- Delivering incremental security architectures through fast release cycles that address security concerns and acting on rapid customer feedback in the context of both the overall solution architecture and the operational environment
- Delivering an MSA for which there is no big upfront planning, but, rather, deferring key decisions around security architecture for as long as possible until more is known
- Anticipating security architecture changes during the development process
- Dividing the security architecture into sub-systems, each with a well-defined boundary and lifecycle

An Agile security architect cannot work in isolation. They must integrate into the secure development lifecycle and support a continuous integration and continuous delivery model. This document does not suggest one form of Agile or iterative approach over another. Rather, this must be about achieving the right approach based on the organization’s risk threshold, culture, and readiness.

2.1. What Does an Agile Security Architect Do?

An Agile security architect always assesses the current (“as is”) and future (“to be”) states. They focus on the most important attributes and do not attempt to solve the whole problem because they do not know everything at any given moment.

Assessing the current and future states implies:

- Shifting from a purely technical exercise to emphasizing resiliency, compliance, and security to address short and long-term business risk
- Providing assurance to business stakeholders that any process used in building the security

architecture is defensible against a security audit; for example, based on industry standards, reference architectures, or well-known frameworks

An Agile security architect must support developers and act as a bridge within a cross-functional team to:

- Facilitate collaboration across product owners, scrum masters, solution architects, test managers, business process architects, and developers
- Identify essential security controls as the solution continually evolves
- Liaise with the enterprise security organization that defines policies on pre-existing tools and practices

Specific responsibilities of an Agile security architect include:

- Understanding the business requirements which the solution seeks to satisfy
- Understanding the organization's appetite for risk with respect to the solution, communicating that risk appetite to the overall team, and monitoring the solution development and implementation to ensure that it stays within the defined risk threshold
- Understanding the overall design from the solution architect, product owner, etc. in a sufficient level of detail to also understand the security aspects of that design
- Advising the solution architect and the development team(s) on security issues, including any constraints due to existing enterprise security practices and tools

Because solutions are delivered in sprints, during which the development teams are invariably fully occupied, it is easy for security concerns to be deferred. An Agile security architect must ensure that security gaps are addressed continually, rather than skipped.

Chapter 3. Governance of an Agile Security Architecture

To fulfill the responsibilities named in the previous chapter, an Agile security architect must team with the business organization(s) responsible for risk management, as well as the functional users of the solution. These groups may include business partners or suppliers.

Because a technology-based solution requires infrastructure and operations support in addition to applications development, a security architect must also team with the providers of supporting capabilities; such as cloud providers, network providers, etc. In all cases, a security architect must understand the security capabilities of these providers and map any gaps to be addressed, as well as security requirements and guardrails within which the solution must fit based on policies defined by enterprise security teams.

Unfortunately, security architects are often a scarce commodity within an organization. One approach to expanding this capacity is to add a supplemental role of “security champion”. A security champion works within one or more solution programs to bring security expertise to the stream-aligned team, league, guild, tribe, etc. and to engage a security architect or product owner when required; therefore, a security champion should have at least a moderate level of security skills and knowledge.

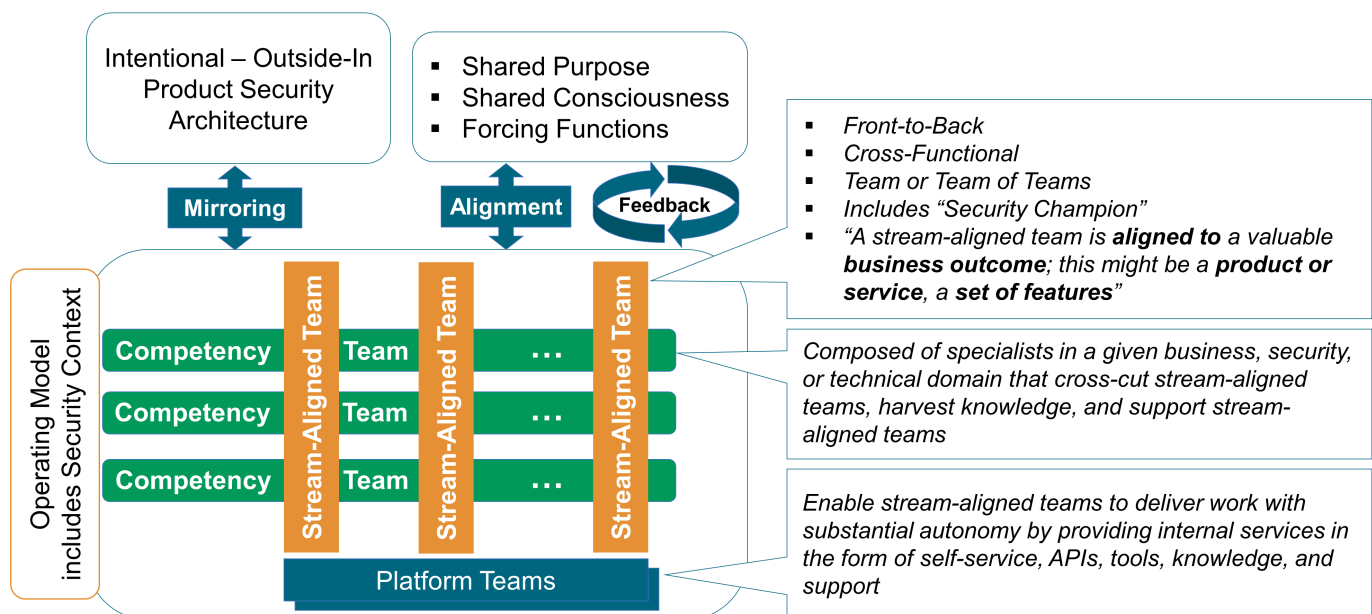


Figure 1. Agile Security Teams Taxonomy

An important responsibility of a security architect/champion is to help the development team(s) understand the risk profile of the solution and the existing enterprise security programs and tools, including any security guardrails which constrain choices in the solution. This should include providing the development team(s) with security education and consulting. If, for example, there are automated security testing tools available, the security architect/champion shall provide help in making use of them.

The security architect/champion must also help teams to understand and use existing security policies, practices, tools, etc. in projects. Instead of re-inventing the wheel every time, teams shall start with known, well-accepted policies, practices, tools, etc. – only developing additions if the existing policies, practices, tools, etc. are inadequate.

A specific responsibility of the security architect/champion is to ensure that development teams do not take the approach of “there will be time to make it secure in a later sprint”. This is a very dangerous path and one where security exposures are highly likely. Additionally, the security architect/champion must work with the scrum master to ensure that sufficient time, frequently a full sprint, is allocated for security testing and remediation in the sprint plan.

Finally, a security architect must be part of the technical governance of the architecture program, including participating in sprint reviews and reviews of architectural decisions and any major design changes.

Chapter 4. Desired Characteristics of Architecting Security

In any organization, threats exploit vulnerabilities and result in asset losses. Security controls are used to reduce the probable Loss Event Frequency (LEF) – the probable frequency, within a given timeframe, that a threat agent will inflict harm upon an asset – and/or probable Loss Magnitude (LM) – the probable magnitude of loss resulting from a loss event – associated with information systems; see The Open Group Standard for Risk Taxonomy (O-RT) [2].

To create a business case for changes in an organization's security controls (often called the security policy and ideally derived from information protection security standards), a quantitative risk analysis, such as that described by the Open FAIR™ risk analysis, should be utilized; if not using a quantitative risk analysis, there must still be a defined and consistent methodology for establishing and discussing risk to determine an organization's appetite for risk and risk threshold.

4.1. Rely on Layers of Controls

Security controls must be designed by starting from the system and information needing protection before then implementing further appropriate layers of protection. This ensures that all the controls are aligned to the protection objective. The project team must seek to understand existing security mechanisms (and related security policies) and how they will serve their project(s). The layers presented below take an inside-out, defense-in-depth approach; see Carlson, 2020 [3].

- Layer 1: Assets – protect the confidentiality, integrity, and availability of applications and their data by designing-in security; also protect unstructured data in file shares
- Layer 2: Security Systems – reduce risk to applications and data while potentially reducing costs by leveraging shared security systems; for example, identity management, access management, key management, authentication, and authorization
- Layer 3: Computing and Network Security – rely on host and network controls to reduce vulnerabilities outside the scope of applications
- Layer 4: Physical Security – understand the protection foundation provided by physical controls
- Layer 5: Personnel Security – employ personnel controls (screening and duty-to-protect) to allow access by trusted insiders

4.2. Employ Application Security Development Practices

The lifecycle for developing and maintaining secure applications must be a component of the system development process employed. A key first step is identifying protection objectives (confidentiality, integrity, or availability) as part of the system's business requirements. Thereafter, the testing of applications for current commonly exploited vulnerabilities is necessary during development activities

and periodically after deployment. [Figure 2](#) depicts the security development process broadly, allowing for the inclusion of Digital Transformation and Agile Architectures.

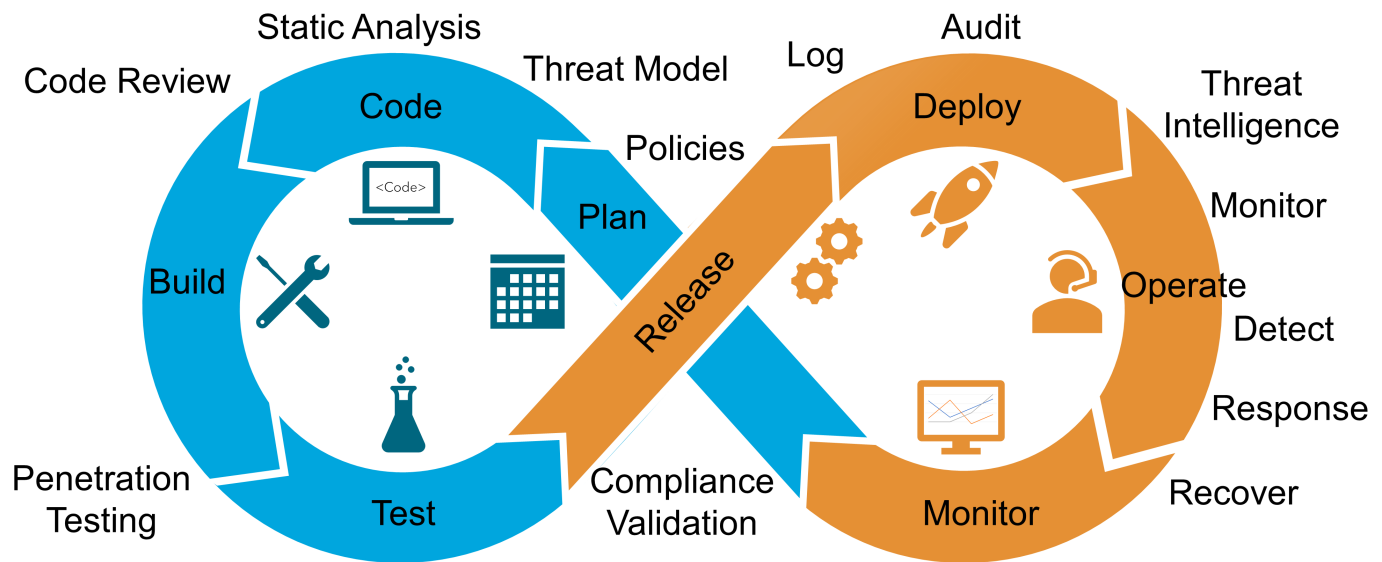


Figure 2. DevSecOps

DevOps is a set of practices and principles that advocates for cross-functional collaboration with a high degree of automation. It includes, but is not limited to, development, operations, and security teams. Within DevOps, security practices need to be embedded throughout the lifecycle. Threat modeling is done at the design stage with deployable artifacts that inject mitigation requirements into the development phase. During development, static analysis ensures code is developed securely. Once the build is complete, dynamic scans ensure functional security is properly addressed. Once a binary is deployed, penetration testing is useful to identify edge cases and to harden production environments.

Because DevOps advocates for automation, output from security, development, and operations should ultimately be gathered in aggregate form to provide security assurance at the program and executive levels. This helps to provide a defensible narrative on the value of DevOps as it addresses the risk posture of the application portfolio within an organization. For more information on DevOps, refer to Bass, Weber, and Zhu, 2015 [4].

Chapter 5. Agile Security Architecture as an Artifact

Achieving this agility in security implies an emphasis on continuous evolution. Besides well-known solution architecture practices like scalability and decoupling, an Agile security architecture adds the following:

- Balancing upfront security planning against future ongoing changes
- Making current security architecture changes based on stable decisions while leaving unstable decisions for later
- Deploying in an ever-changing, heterogeneous, security-driven operational environment
- Logging and monitoring to catch what was missed by automated security testing
- Describing a set of components that can be used as building blocks for future applications
- Loose-coupling in order to support cross-functional Agile activities
- Describing a set of intermediate architectures working toward the end-state

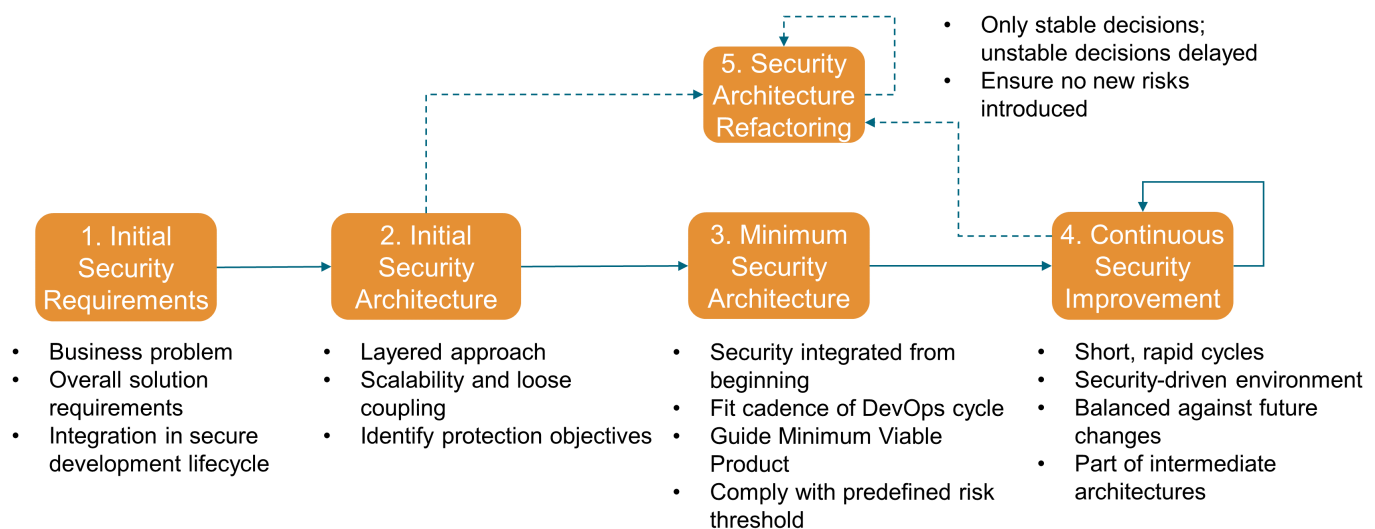


Figure 3. Agile Security Architecture

From the outset, architecting security assumes meeting the needs of various stakeholders. A layered approach shall be used to address distinct security issues, from the business domain down to the technical teams.

When creating a security architecture, measurable quality attributes are essential. The following represents a minimum set of questions that must be asked with each iteration of an Agile security architecture:

- Does the security architecture increase modifiability while reducing upfront design efforts?
- Does the security architecture correctly identify the security context in selecting the implementation strategy?

- Does the security architecture use well-proven architectural styles and design patterns?
- Is the security architecture deployable today?
- Does the security architecture have built-in traceability?
- Does the security architecture allow for rollback if needed?
- Is the security architecture testable and falsifiable?
- Does the security architecture have the built-in mechanisms for monitoring?

An Agile security architecture ultimately provides an ongoing business assurance that the proposed MSA will not introduce any new/additional risk. This is achieved by collaborating with other architects and seeing the gradual emergence of a set of security best practices housed in a Center of Excellence (CoE). This CoE can help create future security-hardened architecture templates that can be reused and can accelerate the creation and deployment of future systems.

Chapter 6. Future Directions

As stated in the introduction, this document did not intend to fully address all IT security considerations for Agile Architectures, but instead offered an overview of the topic and provided links to supplementary materials to provide detail about topics intentionally left brief.

These topics, including the role of DevSecOps, governance of an Agile security architecture, and the role of an Agile security architect, may warrant additional publications in the future to more fully explain them.

Another area for future consideration is the impact of requirements from the Cybersecurity Maturity Model Certification (CMMC) [\[5\]](#).

Appendix A: Acronyms

CMMC

Cybersecurity Maturity Model Certification

CoE

Center of Excellence

LEF

Loss Event Frequency

LM

Loss Magnitude

MSA

Minimum Security Architecture

MVP

Minimum Viable Product

O-AA

Open Agile Architecture

Index

A

Agile, [12](#)

Agile security architect, [12](#)

architect, [12](#)

architecting, [16](#)

C

Center of Excellence, [19](#)

F

feedback loops, [10](#)

G

governance, [14](#)

L

Loss Event Frequency, [16](#)

Loss Magnitude, [16](#)

M

Minimum Security Architecture, [10](#)

Minimum Viable Product, [10](#)

R

risk appetite, [11](#)

S

security, [12](#), [14](#), [16](#)

security architect, [12](#)

security champion, [14](#)

silo thinking, [10](#)

solution architect, [12](#)

sprints, [12](#)